

Matriz de Evaluación PRAGMATIC Completa

Métricas clave AMPARO-ENS

Las siguientes tablas ilustran la evaluación PRAGMATIC de un conjunto de métricas representativas. Cada organización puede ampliarlas o ajustarlas según su contexto. [web:32][web:33][web:21]

Escala sugerida para cada criterio:

0 = No cumple · 1 = Bajo · 2 = Medio · 3 = Alto

1. Métricas de madurez y cumplimiento ENS (G1)

M1.1 - % de medidas ENS implantadas

Criterio	Valor (0-3)	Comentario
Predictivo	2	Si se observa tendencia, permite anticipar riesgos futuros de incumplimiento.
Relevante	3	Directamente vinculada a la adecuación ENS.
Accionable	3	Sirve para priorizar medidas pendientes y planes de adecuación.
Genuino	2	Depende de la honestidad de la autoevaluación y de auditorías periódicas.
Significativo	3	Fácil de entender por dirección y reguladores.
Preciso	2	Puede variar según criterios de “implantado”; mejora con evidencias en AMPARO.
Oportuno	2	Suele actualizarse anualmente; suficiente para ENS, quizá corto para gestión continua.
Independiente	2	Mejora cuando la evaluación la realiza un tercero o auditor acreditado.
Coste-efectivo	2	Requiere esfuerzo de revisión, pero se apoya en DA y auditorías ya existentes.

M1.2 – Edad de la última revisión de la DA (meses)

Criterio	Valor	Comentario
Predictivo	1	Indica riesgo de desalineación futura, pero no resultados concretos.
Relevante	3	Directamente ligada a la vigencia del marco de medidas.
Accionable	3	Si es alta, la acción es obvia: revisar la DA.
Genuino	3	Dato objetivo (fecha), difícil de manipular.
Significativo	2	Requiere explicación a perfiles no técnicos.
Preciso	3	Fecha y cálculo claros.
Oportuno	2	Basta con revisar a cada ciclo de revisión ENS.
Independiente	3	No depende de percepción; se puede verificar documentalmente.
Coste-efectivo	3	Muy barato de obtener.

M1.3 – Frecuencia de revisión de adecuación ENS (años)

Criterio	Valor	Comentario
Predictivo	2	Frecuencias bajas adelantan riesgos de obsolescencia de controles.
Relevante	3	Núcleo del ciclo de mejora ENS.
Accionable	2	A mayor intervalo, más presión para acortarlo, pero requiere recursos.
Genuino	2	Depende de la práctica real, no solo de la norma interna.
Significativo	2	Aclarar a dirección el impacto de revisar cada X años.
Preciso	3	Fácil de identificar.
Oportuno	2	Suficiente para ENS, puede ser insuficiente para entornos muy dinámicos.
Independiente	3	Verificable por calendarios y actas.
Coste-efectivo	3	Obtención trivial.

2. Métricas de riesgo y Zero Trust (G2-G3)

M2.1 – Nivel de formalización de la metodología de riesgos (0-3)

Criterio	Valor	Comentario
Predictivo	2	Una metodología formal aumenta la probabilidad de identificar riesgos futuros.
Relevante	3	Directamente relacionada con ENS art. 35. [web:30]
Accionable	2	Permite planificar la transición desde enfoques ad hoc a formales.
Genuino	2	Puede maquillarse, pero se verifica por documentación y herramientas (PILAR, etc.).
Significativo	2	Requiere explicación a no especialistas.
Preciso	2	Escala simple, pero algo gruesa.
Oportuno	2	Se revisa en cada ciclo de análisis de riesgo.
Independiente	2	Mejora con revisión externa.
Coste-efectivo	3	Muy barato de medir.

M3.1 – % de cuentas privilegiadas con MFA habilitado

Criterio	Valor	Comentario
Predictivo	3	Alta cobertura de MFA reduce probabilidad de compromisos futuros de privilegios.
Relevante	3	Directamente ligada a control de acceso ENS y Zero Trust. [web:2][web:11]
Accionable	3	Fáciles de definir objetivos de mejora (por ejemplo, llegar al 100 %).
Genuino	2	Depende de la veracidad de los inventarios, pero se puede auditar.
Significativo	3	Muy comprensible para dirección.
Preciso	2	Requiere inventario riguroso de cuentas privilegiadas.
Oportuno	3	Se puede extraer automáticamente de directorios y sistemas de identidad.
Independiente	2	Idealmente validable por tercero, pero suele depender del propio equipo de TI.
Coste-efectivo	2	Requiere cierto esfuerzo de inventario inicial, luego su mantenimiento es relativamente barato.

M3.2 – Índice de segmentación de red

Criterio	Valor	Comentario
Predictivo	2	Mejor segmentación reduce el impacto esperado de incidentes.
Relevante	3	Directamente vinculada a protección de redes ENS y Zero Trust.
Accionable	2	Sugiere proyectos de microsegmentación, pero requiere capacidad técnica importante.
Genuino	2	Depende de modelado de red; puede sobre-simplificarse.
Significativo	2	Difícil de explicar sin visualizaciones.
Preciso	2	Medición aproximada, válida para comparar tendencias más que valores absolutos.
Oportuno	1	Actualización no suele ser automática; se basa en documentación y proyectos.
Independiente	2	Mejor con revisión de arquitectura por terceros.
Coste-efectivo	1	Medir bien puede ser costoso; se recomienda cálculo simplificado para uso recurrente.

3. Métricas de operación e incidentes (G4)

M4.1 – MTTD (tiempo medio de detección) de incidentes críticos

Criterio	Valor	Comentario
Predictivo	3	MTTD alto adelanta peores impactos futuros; su mejora predice mayor resiliencia.
Relevante	3	Central en gestión de incidentes ENS y ciberresiliencia. [web:25] [web:6]
Accionable	3	Disparadores claros: mejorar monitorización, procesos, SOC.
Genuino	2	Depende de la calidad de los registros y del criterio de “detección”.
Significativo	3	Fácil de entender: “cuánto tardamos en darnos cuenta”.
Preciso	2	Puede haber errores de registro; suficiente para tendencias.
Oportuno	2	Normalmente se calcula periódicamente (mensual/trimestral).
Independiente	2	Susceptible de optimismo; intervalos auditables desde SIEM/SOC.
Coste-efectivo	2	Requiere integración adecuada de eventos, pero reaprovecha infraestructura existente.

M4.3 – % de incidentes que cumplen RTO/RPO definidos

Criterio	Valor	Comentario
Predictivo	3	Buen cumplimiento indica resiliencia futura en incidentes similares.
Relevante	3	Directamente ligado a continuidad de servicios esenciales (ENS).
Accionable	3	Si se incumple, obliga a revisar capacidad técnica o realismo de RTO/RPO.
Genuino	2	Puede maquillarse; requiere criterios claros de cierre de incidente.
Significativo	3	Clave para dirección: “¿hemos cumplido con lo prometido?”.
Preciso	2	Depende de la calidad de datos de tiempos de caída/recuperación.
Oportuno	2	Se revisa tras ejercicios o incidentes reales.
Independiente	2	Verificable vía registros de disponibilidad y actas de crisis.
Coste-efectivo	2	Necesita algo de disciplina en el registro, pero reutiliza datos de operación.

4. Métricas de recursos, cultura y métricas (G5-G6)

M5.1 – % de presupuesto TI dedicado a ciberseguridad

Criterio	Valor	Comentario
Predictivo	2	No garantiza seguridad, pero inversiones bajas adelantan mayor exposición.
Relevante	3	Fundamental para decisiones de priorización.
Accionable	2	Sirve para justificar aumentos o redistribución presupuestaria.
Genuino	2	Depende de contabilidad interna y fronteras de qué se considera “seguridad”.
Significativo	3	Entendible por direcciones financieras y políticas.
Preciso	2	Precisión razonable, pero con margen de interpretación.
Oportuno	2	Suele disponerse al menos anualmente.
Independiente	2	Puede revisarse por auditoría externa.
Coste-efectivo	3	Dato presupuestario relativamente fácil de obtener.

M6.1 – N° de indicadores de seguridad activos en el cuadro de mando

Criterio	Valor	Comentario
Predictivo	1	La cantidad de indicadores no predice por sí misma resultados, pero refleja madurez.
Relevante	2	Mide la existencia de un sistema de métricas conforme a CCN-STIC-815. [web:32]
Accionable	1	Exceso de indicadores puede ser contraproducente; acción sutil.
Genuino	3	Dato comprobable de manera directa.
Significativo	2	Más importante es su contenido que el número; requiere contexto.
Preciso	3	Contar no tiene misterio.
Oportuno	2	Se revisa cuando se actualiza el cuadro de mando.
Independiente	3	Fácilmente verificable.
Coste-efectivo	3	Esencialmente gratuito.

5. Uso práctico de la matriz PRAGMATIC

1. Seleccionar las métricas que se desean incorporar al cuadro de mando ENS/INES/AMPARO. [web:21][web:39]
2. Evaluar cada métrica con la matriz PRAGMATIC, pudiendo ajustar los valores a la realidad local.
3. Eliminar o revisar aquellas métricas que sistemáticamente puntúen bajo en más de 3–4 criterios.
4. Priorizar, para el uso ejecutivo, las métricas con mejor combinación de Predictivo, Relevante, Accionable y Significativo.
5. Documentar la evaluación (incluyendo esta matriz) para facilitar auditorías, revisiones y diálogo con órganos de gobierno.

La métrica perfecta no existe, pero la métrica consciente de sus limitaciones está bastante cerca.